

Федеральное государственное автономное образовательное учреждение
высшего образования
«Национальный исследовательский университет ИТМО»

Информационная безопасность
**Работа 2: Анализ и устранение уязвимости на примере
реального CVE с использованием Vulhub**

Выполнил:

Баянов Равиль Динарович

Группа:

P3434

г. Санкт-Петербург

2025

Содержание

ВЫБРАННАЯ УЯЗВИМОСТЬ.....	3
ПОСЛЕДОВАТЕЛЬНОСТЬ ДЕЙСТВИЙ.....	4
АНАЛИЗ ROOT CAUSE	6
ОПИСАНИЕ ПРИМЕНЕННОГО ИСПРАВЛЕНИЯ	7
ДОКАЗАТЕЛЬСТВО УСТРАНЕНИЯ УЯЗВИМОСТИ.....	8
ВЫВОД	9

Выбранная уязвимость

CVE-2021-43798 - Path Traversal в Grafana 8.x

Уязвимость представляла собой классическую атаку типа Path Traversal в модуле обработки плагинов Grafana. Механизм обслуживания статических файлов плагинов не выполнял должной проверки входных данных, что позволяло злоумышленникам выходить за пределы предназначенных директорий с помощью последовательности ../.

Последовательность действий

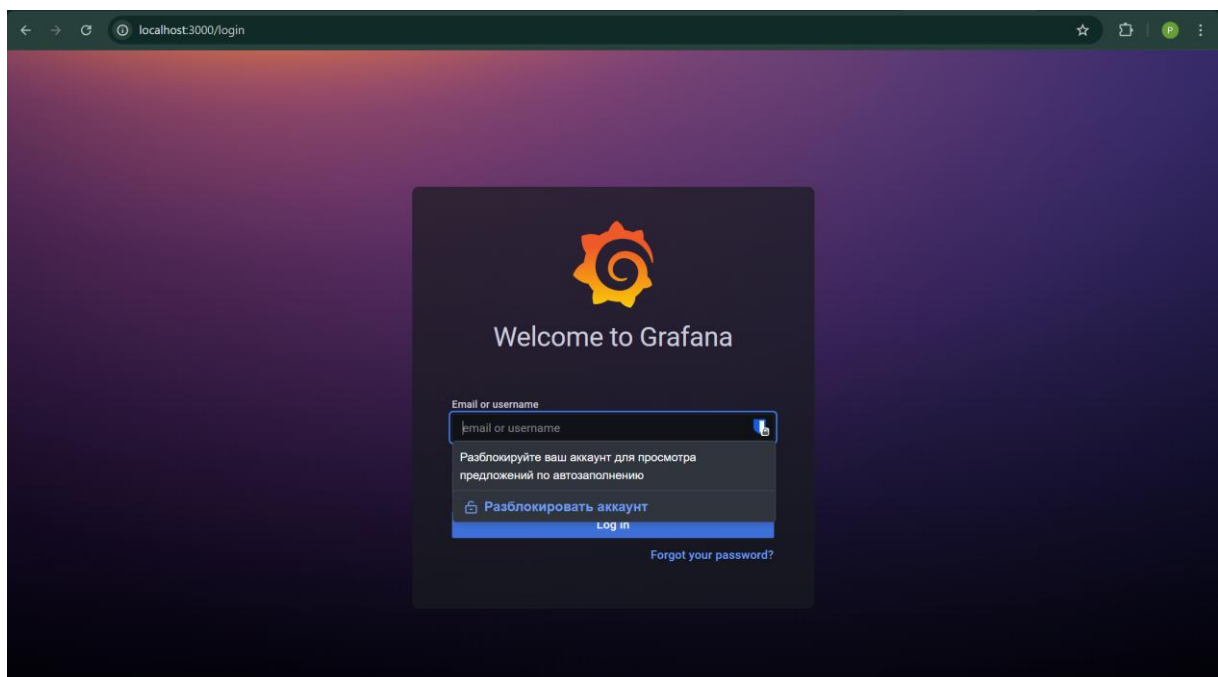
Для воспроизведения уязвимости следует сначала запустить уязвимую среду через Docker:

```
cd grafana-cve-2021-43798
docker compose up -d
```

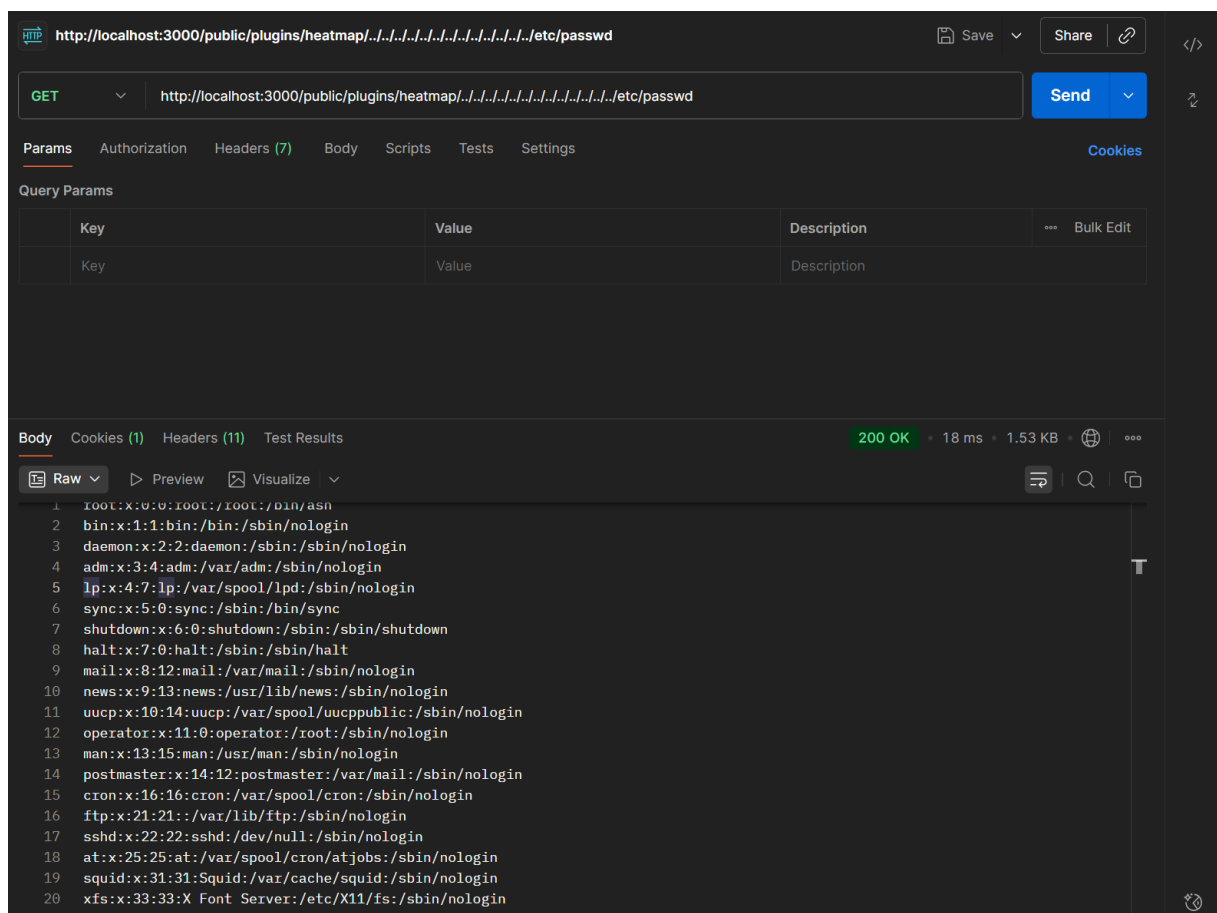
```
PS C:\Users\RavvCheck1\IdeaProjects\vu\hub\grafana\CVE-2021-43798> docker compose up -d
time="2025-10-21T00:12:05+03:00" level=warning msg="C:\Users\RavvCheck1\IdeaProjects\vu\hub\grafana\CVE-2021-43798\docker-compose.yml: the attribute `version` is obsolete, it will be ignored, please remove it to avoid potential confusion"
[+] Running 10/10
  ✓ web Pulled                                                                                               14.5s
  ✓ 97518928ae5f Pull complete                                                                              1.0s
  ✓ 5aba0f6bfd98 Pull complete                                                                              1.1s
  ✓ 3694b5a562ee Pull complete                                                                              1.6s
  ✓ bff44df695f9 Pull complete                                                                              2.9s
  ✓ 24c1ec8cf9df Pull complete                                                                              4.1s
  ✓ 17fd2cee9f08 Pull complete                                                                              11.6s
  ✓ 4f4fb700ef54 Pull complete                                                                              11.6s
  ✓ dc3505db7303 Pull complete                                                                              11.7s
  ✓ 046f9a37e741 Pull complete                                                                              11.8s
[+] Running 2/2
  ✓ Network cve-2021-43798_default Created                                                                0.1s
  ✓ Container cve-2021-43798-web-1 Started                                                                2.5s
PS C:\Users\RavvCheck1\IdeaProjects\vu\hub\grafana\CVE-2021-43798>
```

Затем проверим доступность Grafana на локальной машине:

```
http://localhost:3000
```



Теперь выполним запрос из описания в Readme.md уязвимости:



Заметим, что мы получили доступ к локальному файлу приложения `passwd`, в котором хранится информация обо всех системных пользователях.

Анализ root cause

Проблема данной уязвимости заключалась в том, что приложение было реализовано так, что никак не валидировался `filePath`, с помощью которого можно было проникнуть в закрытые директории и просмотреть секретные системные файлы приложения. Нужно было проверять остается ли пользователь в пределах разрешенной директории плагина.

Описание примененного исправления

Разработчики быстро среагировали на данную уязвимость и в новой версии исправили эту ошибку

Исправили эту ошибку тем, что в код добавили проверку на то, что новый путь начинается с корневой директории плагина, а также теперь перед выполнением запроса очищаются последовательности из дублированных точек.

```
func (hs *HTTPServer) ServePluginAsset(w http.ResponseWriter, r
*http.Request) {
    // ... получение pluginID и filePath ...

    // ДОБАВЛЕНА ПРОВЕРКА БЕЗОПАСНОСТИ
    cleanedPath := filepath.Clean(filepath.Join(plugin.PluginDir, "assets",
filePath))
    if !strings.HasPrefix(cleanedPath, filepath.Clean(plugin.PluginDir)) {
        http.NotFound(w, r)
        return
    }
}
```

Доказательство устранения уязвимости

Поднимем версию приложения до той, в которой уязвимость была устранена, например 8.3.1:

version: '2'

services:

web:

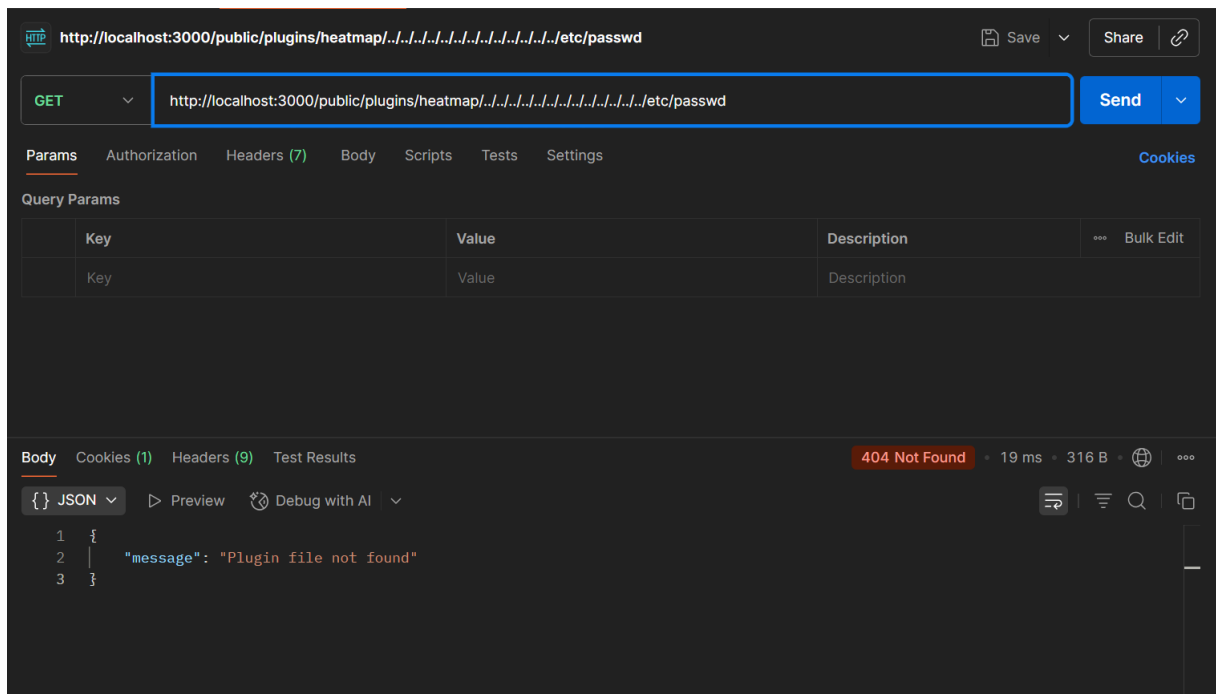
image: grafana/grafana:8.3.1

ports:

- "3000:3000"

```
PS C:\Users\RavvCheck1\IdeaProjects\vulhub\grafana\CVE-2021-43798> docker compose up
time="2025-10-21T01:01:04+03:00" level=warning msg="C:\Users\RavvCheck1\IdeaProjects\vulhub\grafana\CVE-2021-43798\docker-compose.yml: the attribute `version` is obsolete, it will be ignored, please remove it to avoid potential confusion"
[+] Running 11/11
  ✓ web Pulled                                41.7s
  ✓ 97518928ae5f Already exists                0.0s
  ✓ a8f5f0c09c3c Pull complete                 1.2s
  ✓ 9643e582a667 Pull complete                 2.3s
  ✓ ad4af0290117 Pull complete                 2.3s
  ✓ d896601a4afa Pull complete                 6.1s
  ✓ 65e4610b9997 Pull complete                 12.4s
  ✓ e64bd165f497 Pull complete                 38.9s
  ✓ 6f30ef198861 Pull complete                 39.0s
  ✓ 48ef5f0dbcfe Pull complete                 39.1s
  ✓ d895202b1b92 Pull complete                 39.1s
[+] Running 2/2
  ✓ Network cve-2021-43798_default Created      0.1s
  ✓ Container cve-2021-43798-web-1 Started      1.3s
PS C:\Users\RavvCheck1\IdeaProjects\vulhub\grafana\CVE-2021-43798>
```

Теперь выполним тот же запрос, который выполняли в среде с уязвимостью и заметим, что мы больше не можем получить доступ к системным файлам – мы получаем ошибку 404:



Вывод

Выполнив, данную лабораторную работу я закрепил для себя знание о такой уязвимости как, Path Traversal. Теперь я буду иметь ввиду то, что если неправильно валидировать путь к директориям, который вводит пользователь, злоумышленник может получить доступ к системным данным и использовать их в свои целях.